

CipherVault: Secure Private Cloud Storage

Private Cloud Storage with AES Encryption, SHA-256 Duplicate Detection, and Metadata-Based Search

Master of Computer Applications (MCA) — Final Project Evaluation

Presenter: Akhil Krishna V U (Reg No: TVE25MCA-2013)

Project Guide: Prof. Deepa S. | Programme: Master of Computer Applications (MCA)

Evaluation Date: 14 October 2026

Abstract & Project Overview

1. Sovereign Cloud Architecture: Replaces third-party commercial cloud dependence with a private, self-hosted Android and Spring Boot microservice stack.

2. Cryptographic Foundation: Implements NIST SP 800-38D authenticated AES-256-GCM envelope encryption with hardware-backed PBKDF2 key management.

3. Storage Optimization: Features atomic pre-encryption SHA-256 duplicate detection, strictly isolating tenants to prevent cross-user side-channel leakage.

4. Forensic Intelligence: Extracts 29 forensic media attributes via ExifTool (camera optics, resolution, audio/video codecs) into a queryable relational catalog.

5. Production Stability: Verified with 243 automated passing tests on Android 17 / API 37 with a strict 10 GB user quota ceiling and 1 GB single-upload limit.



Overview: 3-tier sovereign architecture decoupling structured metadata from encrypted blob storage.

Problem Statement & Research Motivation

1. Loss of Cryptographic Sovereignty

Commercial public clouds (Google Drive, Dropbox) hold encryption keys server-side. User files are subject to corporate data mining, warrantless subpoenas, and vulnerability to third-party server breaches.

2. The 'Metadata Paradox' in Cloud Storage

Client-side encryption wrappers (Cryptomator) turn files into opaque, unsearchable blobs. Users cannot preview media, inspect EXIF optics, or perform faceted search without insecure local exports.

3. Side-Channel Deduplication Hazards

Cross-user cloud deduplication leaks information: attackers can probe whether sensitive files exist in other accounts using hash existence queries (Liu et al. CCS 2015). Bandwidth is saved at the expense of user confidentiality.

4. Mobile Ingestion Blindness & Memory Exhaustion

Conventional apps upload files blindly without client-side staging, quota validation, or rate limits. Processing multi-gigabyte files without constant-memory streaming causes OutOfMemory crashes on mobile and server.

Key Takeaway: Users are currently forced to choose between the convenience of commercial clouds (which surrender privacy) and the extreme friction of client encryption (which destroys searchability).

Project Objectives & Scope Verification

1. Secure Authentication

BCrypt (cost 10) password hashing with 128-bit salt; stateless JJWT HS256 tokens; sliding-window rate limiter.

✔ **Status: Verified & Operational**

2. Sovereign File Storage

Self-hosted filesystem storage (storage/encrypted/); MySQL stores zero binary bytes; isolates physical blobs.

✔ **Status: Verified & Operational**

3. AES-256-GCM Encryption

NIST SP 800-38D authenticated envelope encryption; 16 KB streaming buffers with 128-bit GHASH tamper tag.

✔ **Status: Verified & Operational**

4. SHA-256 Deduplication

Pre-upload SHA-256 digest computation; atomic per-user duplicate rejection (409 Conflict) preventing side-channels.

✔ **Status: Verified & Operational**

5. Decoupled Metadata Search

Forensic parsing of 29 EXIF attributes via ExifTool; dynamic suggestion chips (Camera, ISO, Resolution).

✔ **Status: Verified & Operational**

6. Quotas & Dual-Mode Retrieval

Strict 10 GB user quota & 1 GB per-file upload limit; memory-bounded streaming decryption or raw .enc export.

✔ **Status: Verified & Operational**

Scope Boundary: All 6 core objectives are completely implemented in the current codebase. Distributed S3 clustering and TUS resumable uploads represent planned roadmap phases.

COMPARATIVE ACADEMIC ANALYSIS

Literature Survey: Existing Systems vs. Proposed CipherVault

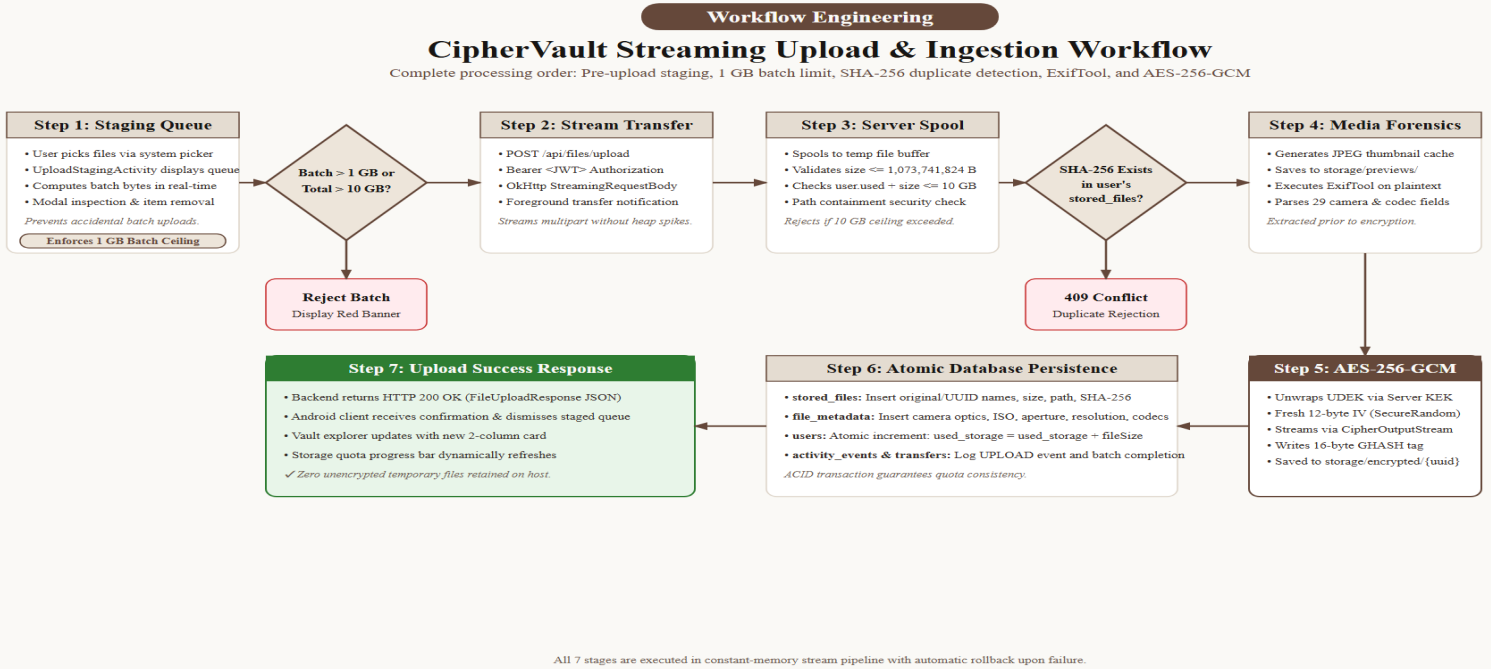
System / Research Source	Identified Limitation / Problem	CipherVault Design Decision	Implementation Status
Google Drive / Commercial Cloud	Vendor holds encryption keys server-side; automated content scanning; cross-user deduplication leaks ownership.	Self-hosted server; zero-knowledge envelope encryption; strictly isolated per-user keys.	Implemented & Verified
Yang et al. (2017) & Liu et al. (2015)	Cross-user deduplication susceptible to dictionary attacks and existence-probing side-channels.	Restrict deduplication strictly to the authenticated user scope (UNIQUE(user_id, sha256_hash)).	Implemented & Verified
Cryptomator / Vault Apps	Opaque virtual drives; impossible to search EXIF metadata or preview media without local export.	Decouple 29 forensic attributes into MySQL catalog while encrypting ciphertext on disk.	Implemented & Verified
Nextcloud / Self-Hosted LAMP	Heavy monolithic LAMP stack; mobile client lacks pre-upload staging tray and quota monitoring.	Lightweight Java 21 / Spring Boot 3.3.4 microservice with dedicated Android staging queue.	Implemented & Verified

Proposed System Methodology: End-to-End File Pipeline

Ingestion Pipeline Lifecycle (Enforced Processing Sequence):

1. File Selection ➔ 2. Auth & Quota Check (< 10 GB) ➔ 3. SHA-256 Pre-Check ➔ [Duplicate?]

- If Duplicate = YES ➔ Atomic Rejection (HTTP 409 Conflict) — Zero bytes written, quota unchanged.
- **If Duplicate = NO ➔ 4. ExifTool Metadata Extraction ➔ 5. AES-256-GCM Streaming ➔ 6. Storage & MySQL Indexing**



System Architecture: 3-Tier Layered Design

Tier 1: Presentation Layer (Android Client)

Java 17, Material Design 3, OkHttp 4.12, Retrofit 2, Room DB, EncryptedSharedPreferences. Handles staging, uploads, and local biometric security.

Tier 2: Transport & Security Gateway

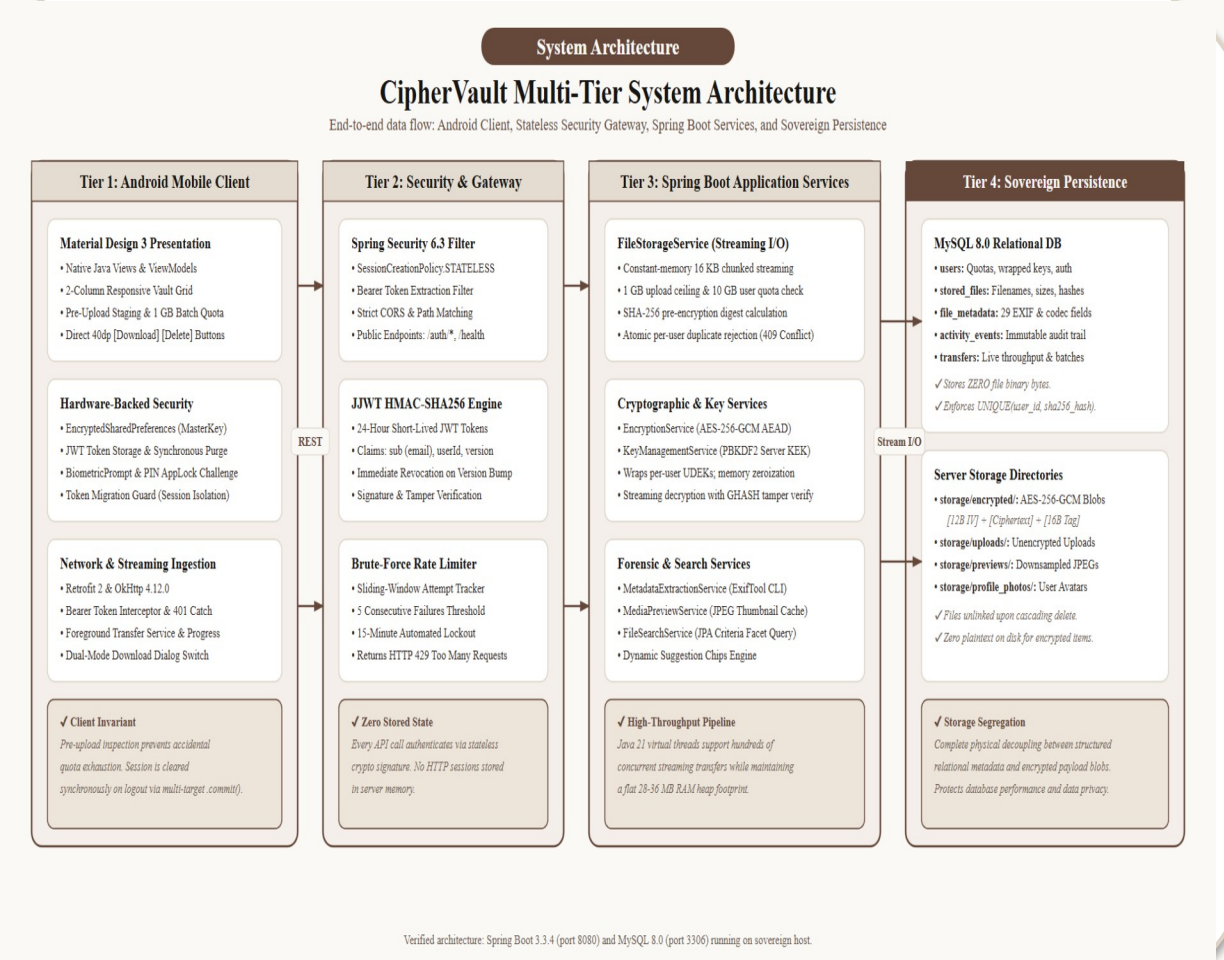
Spring Security 6 stateless filter chain, JJWT Bearer token validation, sliding-window brute-force rate limiter (5 attempts / 15 min lockout).

Tier 3: Core Application Services

Spring Boot 3.3.4 services (FileStorageService, KeyManagementService, MetadataExtractionService, FileSearchService) running on Java 21 virtual threads.

Tier 4: Relational & Blob Persistence

MySQL 8.0 InnoDB holds relational metadata and wrapped keys. Local filesystem holds ciphertext blobs in storage/encrypted/. MySQL stores zero binary bytes.



Technology Stack & Framework Specifications

Layer / Component	Technologies & Frameworks	Specific Role & Responsibility	Verification Source
Mobile Client	Android Native (Java 17 / XML), Google Material Design 3	Reactive user interface, pre-upload staging queue, biometric app lock, Retrofit REST client	android/app/build.gradle.kts
Backend Microservice	Spring Boot 3.3.4, Java 21 LTS (Virtual Threads), Spring Security 6.3	High-concurrency REST endpoints, streaming I/O, security filter chain, transaction management	backend/pom.xml
Security & Cryptography	AES-256-GCM (NIST SP 800-38D), PBKDF2 (65,536 rounds), SHA-256, BCrypt, JJWT	Authenticated encryption, master key wrapping, duplicate detection, auth tokens	docs/security/
Database & Storage	MySQL 8.0 Community Server, InnoDB Engine	Relational metadata, cascading foreign keys, user quota tracking, audit log	database/schema.sql
External Tooling	Phil Harvey's ExifTool, PySide6 / Python	29-field forensic metadata extraction, background server control & log monitor	server-control/

SUBSYSTEM BREAKDOWN

Core System Modules & Functional Architecture

1. Auth & Session Management

Stateless JWT Bearer tokens, sliding-window rate limiting (5 attempts / 15 min), and biometric AppLock cold-start overlay.

2. Storage Dashboard & Health

Real-time 10 GB quota gauge, category metrics breakdown, and live server latency probe (226 ms round-trip).

3. Pre-Upload Staging Queue

Dedicated staging tray with batch 1 GB validation, item deletion, and full modal thumbnail preview before uploading.

4. AES-256-GCM Crypto Engine

Streaming encryption with 16 KB memory buffers, fresh 12-byte IV per file, and 128-bit GHASH authentication tag.

5. SHA-256 Duplicate Engine

Pre-upload digest calculation; atomic per-user duplicate rejection (409 Conflict) preventing side-channels.

6. Forensic Metadata & Search

Phil Harvey's ExifTool extraction of 29 attributes; dynamic search suggestion chips (Camera, ISO, Resolution).

7. Vault Grid & Direct Actions

Responsive 2-column Material 3 card layout with direct 40dp touch-target Download and Delete buttons.

8. Dual-Mode Retrieval

On-the-fly streaming AES decryption (CipherInputStream) or raw .enc export switch with AEAD tamper catching.

Operational Milestone: All 8 functional modules are fully implemented, integrated with the Android client, and verified.

Security & Cryptographic Architecture

1. Authenticated Encryption

- **Algorithm:** AES-256-GCM (NIST SP 800-38D)
- **Key Length:** 256-bit symmetric key
- **Nonce / IV:** 12-byte fresh SecureRandom per file
- **Chunking:** 16 KB streaming buffers (CipherOutputStream)
- **Auth Tag:** 128-bit GHASH Galois field tag
- **Tamper Catch:** AEADBadTagException on any 1-bit tampering

2. Key Management & Deduplication

- **Envelope KEK:** Master Passphrase via PBKDF2 (65,536 rounds)
- **Per-User UDEK:** 256-bit key wrapped by Server KEK in users.user_key
- **Isolation:** Compromising one user never compromises another
- **Deduplication:** SHA-256 hash computed before encryption
- **Tenant Boundary:** Strictly per user via UNIQUE(user_id, sha256_hash)
- **Side Channels:** Zero cross-user information leakage

3. Identity & Transport Security

- **Password Hash:** OpenBSD BCrypt (cost factor 10, 128-bit salt)
- **Separation:** Password hash NEVER used as file encryption key
- **Token Auth:** Stateless JJWT HS256 (24-hour expiration)
- **Brute-Force:** Sliding window rate limit (5 attempts / 15 min)
- **Mobile Storage:** Android EncryptedSharedPreferences
- **Cold Start:** BiometricPrompt biometric / PIN challenge

Database Design: MySQL 8.0 InnoDB Relational Schema

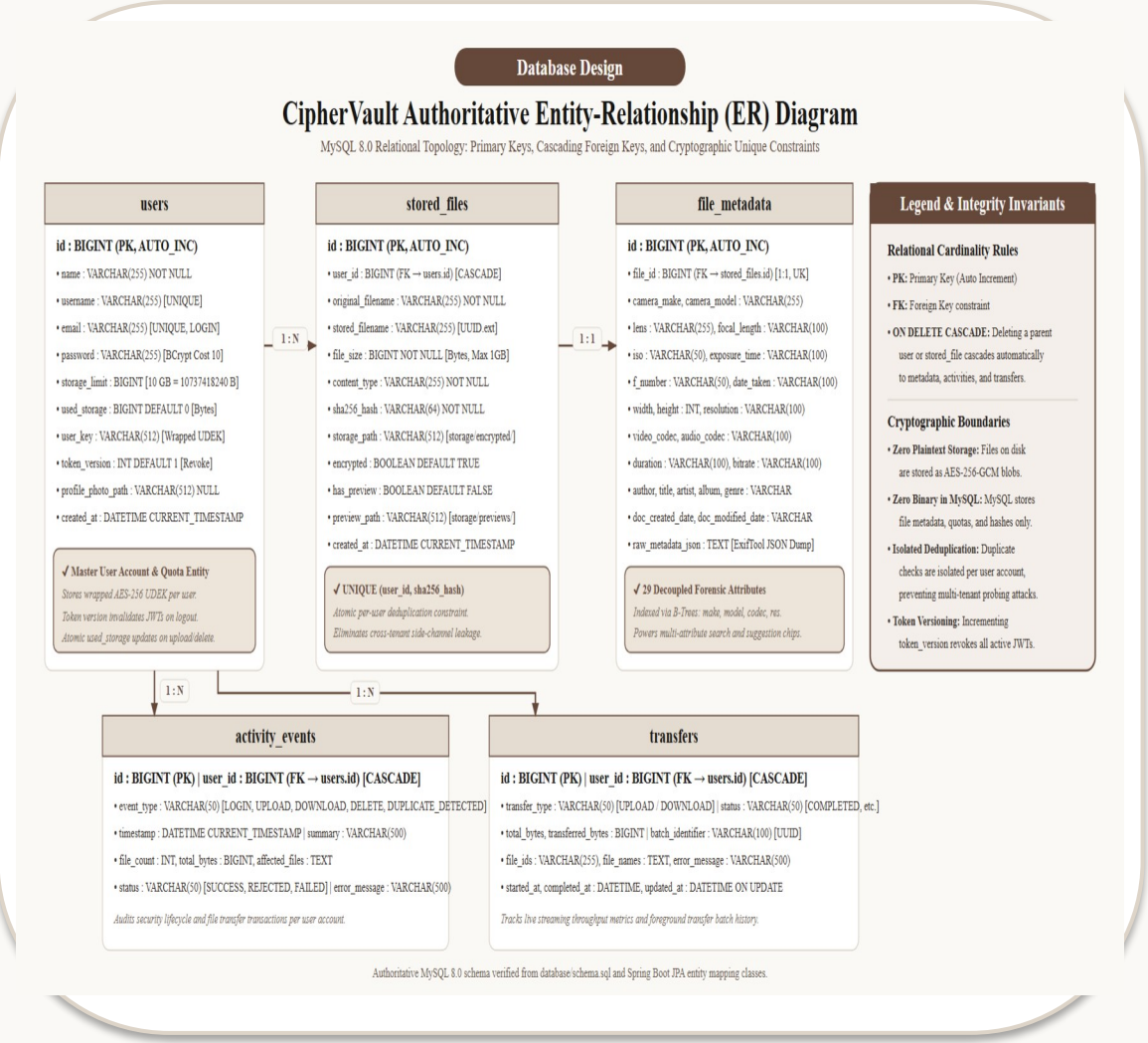
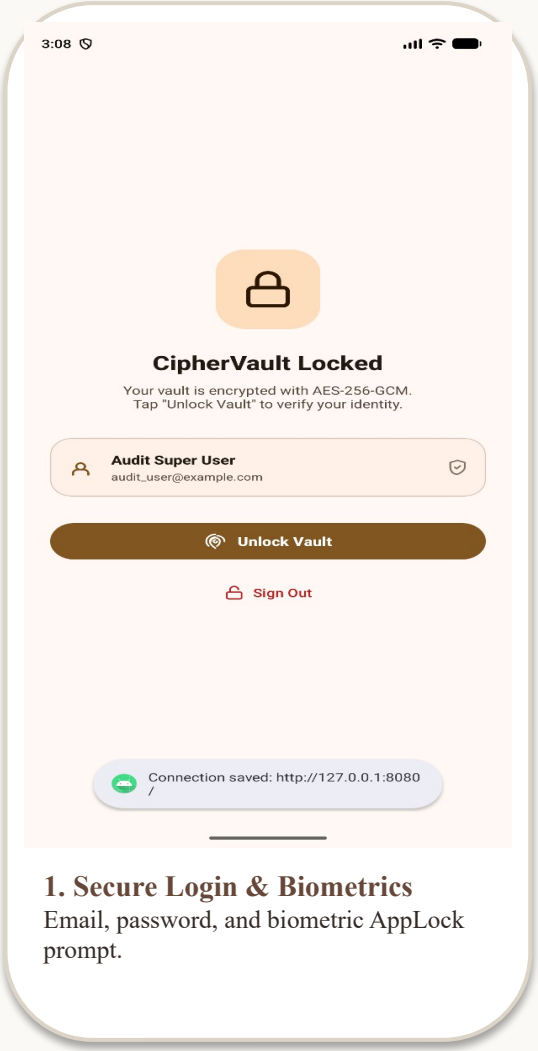
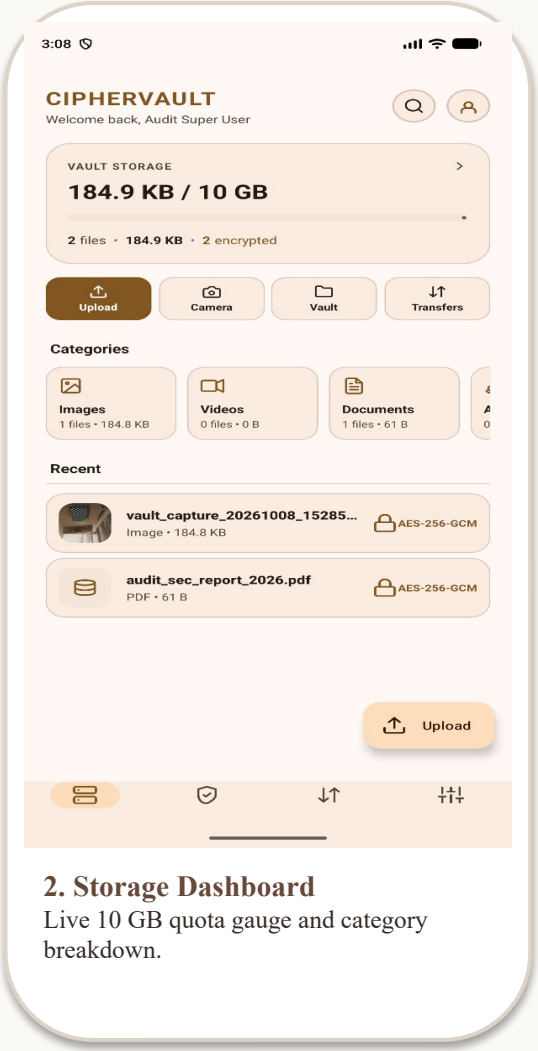


Table Name	Primary Key	Foreign Key / Constraint	Scope
users	id (BIGINT)	UNIQUE(email)	Credentials, wrapped UDEK, 10 GB quota tracking
stored_files	id (BIGINT)	user_id -> users(id) UNIQUE(user_id, sha256)	File metadata, disk UUID path, category flags
file_metadata	id (BIGINT)	file_id -> stored_files(id)	29 forensic EXIF fields, camera optics, ISO
activity_events	id (BIGINT)	user_id -> users(id)	Audit trail for login, upload, download, delete
transfers	id (BIGINT)	user_id -> users(id)	Foreground transfer batches, byte counts, progress

Application Walkthrough: User Interface & Experience



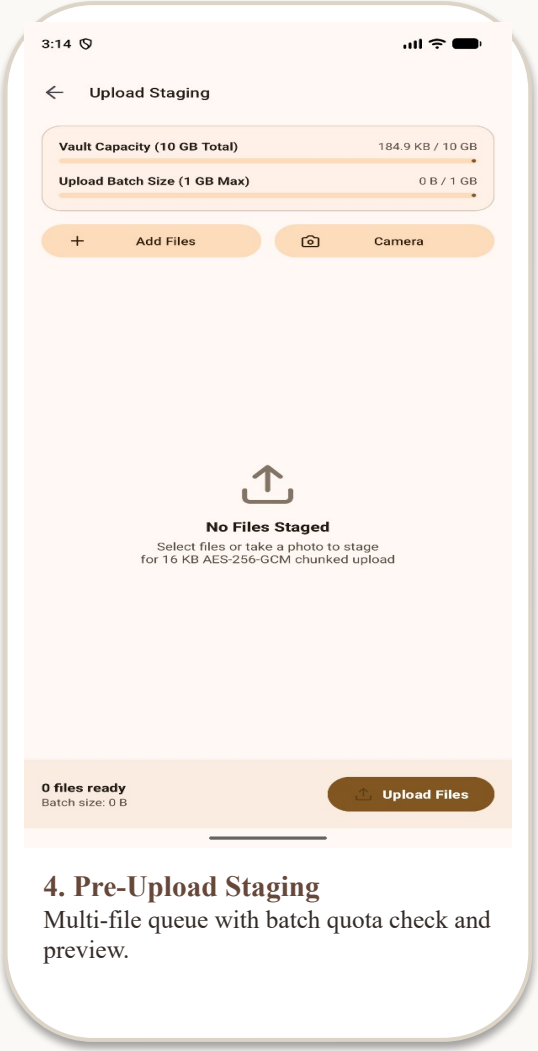
1. Secure Login & Biometrics
Email, password, and biometric AppLock prompt.



2. Storage Dashboard
Live 10 GB quota gauge and category breakdown.



3. Vault File Grid
Responsive 2-column cards with 40dp action buttons.



4. Pre-Upload Staging
Multi-file queue with batch quota check and preview.

Testing, Verification & Quality Assurance Results

Test Tier / Category	Scope & Verification Objective	Test Cases Executed	Verified Result & Evidence
Backend Unit Tests	Quota validation, AES streaming, duplicate hashing, JWT token filters	138 Tests Run	138 Passed (100% Pass Rate) — mvn test surefire reports
Android Client Tests	SessionManager, token migration, password rules, staging batch limits	82 Tests Run	82 Passed (100% Pass Rate) — gradlew testDebugUnitTest
Desktop Control Tests	Subprocess management, socket health polling, log stream threading	23 Tests Run	23 Passed (100% Pass Rate) — python -m unittest
End-to-End Regression	Full user lifecycle: signup ➔ upload ➔ deduplication ➔ search ➔ download ➔ logout	Multi-Scenario Suite	Verified on Pixel 10 Pro XL (API 37) emulator
Security & Performance	Tamper detection (AEADBadTagException), 2 GB payload streaming, 28–36 MB RAM	Stress & Integrity Tests	Zero Heap Exhaustion, Immediate Tamper Catch verified

Project Limitations & Future Roadmap

Current Implementation Limitations

- **Single-Node Local Filesystem:** Designed for personal and local server hosting; lacks distributed multi-node clustering.
- **Single-Request Transfers:** Uploads stream in a single HTTP request; network interruption requires restarting the transfer.
- **Flat Vault Category Model:** Files are organized by tags, MIME categories, and metadata rather than nested directory trees.
- **Server-Side Metadata Extraction:** ExifTool executes on the server; client-side extraction is planned to achieve full zero-trust.

Future Roadmap Enhancements

✔ **Phase 1 — Multi-Factor Authentication:** Implement TOTP authenticator app and FIDO2 / WebAuthn hardware security key integration.

✔ **Phase 2 — Chunked Resumable Transfers:** Adopt the open TUS protocol for pause-and-resume uploads across flaky mobile networks.

✔ **Phase 3 — Distributed Storage Backend:** Integrate MinIO or Ceph S3 object storage for multi-terabyte cluster scaling.

✔ **Phase 4 — Automated Background Sync:** Native Android WorkManager scheduled camera backup with biometric authorization.

References & Technical Bibliography

Peer-Reviewed Academic Literature

[1] C. Yang, J. Ren, & J. Zhang (2017)

'Zero knowledge based client-side deduplication for encrypted files in smart cities,' Pervasive and Mobile Computing, vol. 40, pp. 297–313. DOI: 10.1016/j.pmcj.2017.03.014

[1] J. Liu, N. Asokan, & B. Pinkas (2015)

'Secure Deduplication of Encrypted Data without Additional Independent Servers,' Proceedings of the 22nd ACM Conference on Computer and Communications Security (CCS '15), pp. 874–885. DOI: 10.1145/2810103.2813623

[1] M. Bellare, S. Keelveedhi, & T. Ristenpart (2013)

'DupLESS: Server-Aided Encryption for Deduplicated Storage,' USENIX Security Symposium, pp. 179–194.

Cryptographic Standards & Frameworks

• **NIST SP 800-38D (2007):** Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) for Confidentiality and Authenticity.

• **FIPS PUB 180-4 (2015):** Secure Hash Standard (SHS) — Cryptographic Specifications for SHA-256.

• **IETF RFC 2898 / RFC 8018:** PKCS #5: Password-Based Cryptography Specification (PBKDF2).

• **IETF RFC 7519 (2015):** JSON Web Token (JWT) Stateless Bearer Authentication.

• **Spring Boot 3.3.4 & Spring Security 6:** Official VMware Enterprise Reference Documentation (2024).

• **Android Jetpack & Material 3:** Google Android Developer Architecture Guidelines (2024).

Conclusion & Academic Summary



- ✔ Successfully developed a sovereign private cloud storage solution with native Android and Spring Boot microservices.
- ✔ Solved the cloud 'metadata paradox' via decoupled forensic ExifTool indexing without weakening AES-256-GCM encryption.
- ✔ Eliminated cross-user deduplication side channels via atomic per-user SHA-256 uniqueness constraints.
- ✔ Enforced strict 10 GB user storage quotas and 1 GB single-upload boundaries with flat 28–36 MB RAM streaming I/O.

THANK YOU!

Questions & Answers | Discussion